CASE STUDY + PRD · NOVEMBER 2026

Getting a new IT admin to their first working policy

An onboarding redesign concept for Cloudflare Zero Trust, built from public docs and public posts

Krupa Nirmal

What I counted	Count
Public signals coded (Community, Reddit, G2, X, Gartner)	60
…of which describe friction	56
Friction clusters (top 5 cover 50 of 56)	8
Documented steps, shortest path to one protected device	29 across 5 doc pages
Same path with Entra ID as the identity provider	50
Concept screens	5
A/B tests designed	2

Independent concept. Not affiliated with or endorsed by Cloudflare. Built only from public information; mockups use synthetic data and no Cloudflare branding. Every count traces to a file in this repo; every outcome is a hypothesis.

1. The problem

Cloudflare Zero Trust lets a company filter its employees' internet traffic and put internal apps behind identity checks. Setup is self-serve: create an organization, pick a sign-in method, install a client on a device, write a policy. Nothing is protected until all four are done.

Public posts suggest many new admins stop somewhere in that chain. The most common specific failure is a device refused at enrollment, before any sign-in screen appears. Cloudflare's own March 2026 post on onboarding says new tenants are "typically provisioned with a blank slate" and that deploying a baseline by hand "would take several hours" (blog.cloudflare.com/cloudflare-one-onboarding-project-helix, accessed 11 Nov 2026).

Who this is for. An IT admin at a company of 200–2,000 people, often a team of one to three, evaluating Zero Trust alongside other work. Job to be done: "Show me it works on one real laptop this week, so I can decide whether to roll it out."

First value. One enrolled device whose traffic is checked by at least one policy the admin wrote. That is the activation event used throughout.

One detail matters for this persona. The public plans page positions the Free plan as "Best for teams under 50 users or enterprise proof-of-concept tests" (cloudflare.com/plans/zero-trust-services, accessed 11 Nov 2026). So a 200–2,000 person company likely starts on Free as a proof of concept, which is the self-serve path studied here.

2. How I did it

- **Docs walk-through.** I read every page on the path from signup to first policy, on the Dashboard tab, and counted steps. Rule: one numbered instruction = one step. Screenshots of each page are in /screens.
- **Public signals.** I searched Cloudflare Community, Reddit (r/CloudFlare, r/sysadmin, r/cybersecurity), G2, Gartner Peer Insights and X for setup problems. I kept 60 signals dated 2022 or later and excluded 16 (14 personal or home use, 2 pre-2022). Each row has a URL, date, stage and cluster; no usernames are stored.
- **Coding.** Each signal got one stage (0 = across all stages, 1–4 = the stages below) and one cluster. I did the coding alone, so treat clusters as a first pass.
- **What I could not do.** I did not sign in to the dashboard, so nothing here is click-tested. I could not read full Gartner reviews (login wall), and Reddit blocked direct fetches, so those posts came through search snippets and post bodies.

Sample bias. Forum posts come from people who got stuck, so they over-represent failure. 33 of 60 signals are from one source (Cloudflare Community). For 28 of 60 I could not tell whether the poster was at a company. Review-site snippets are short and general. A few Reddit dates are month-level only. The counts rank themes inside this sample; they are not rates and say nothing about how many admins fail.

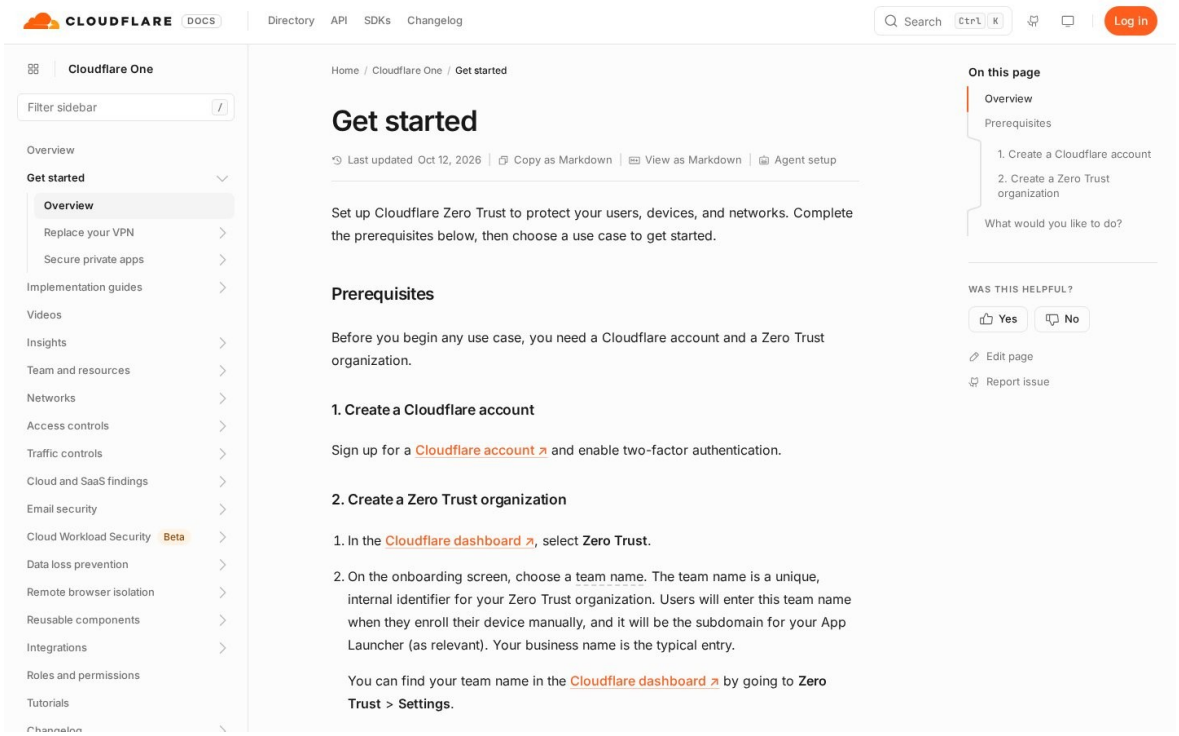
3. The current journey

Four stages, counted from the public docs on 11 Nov 2026.

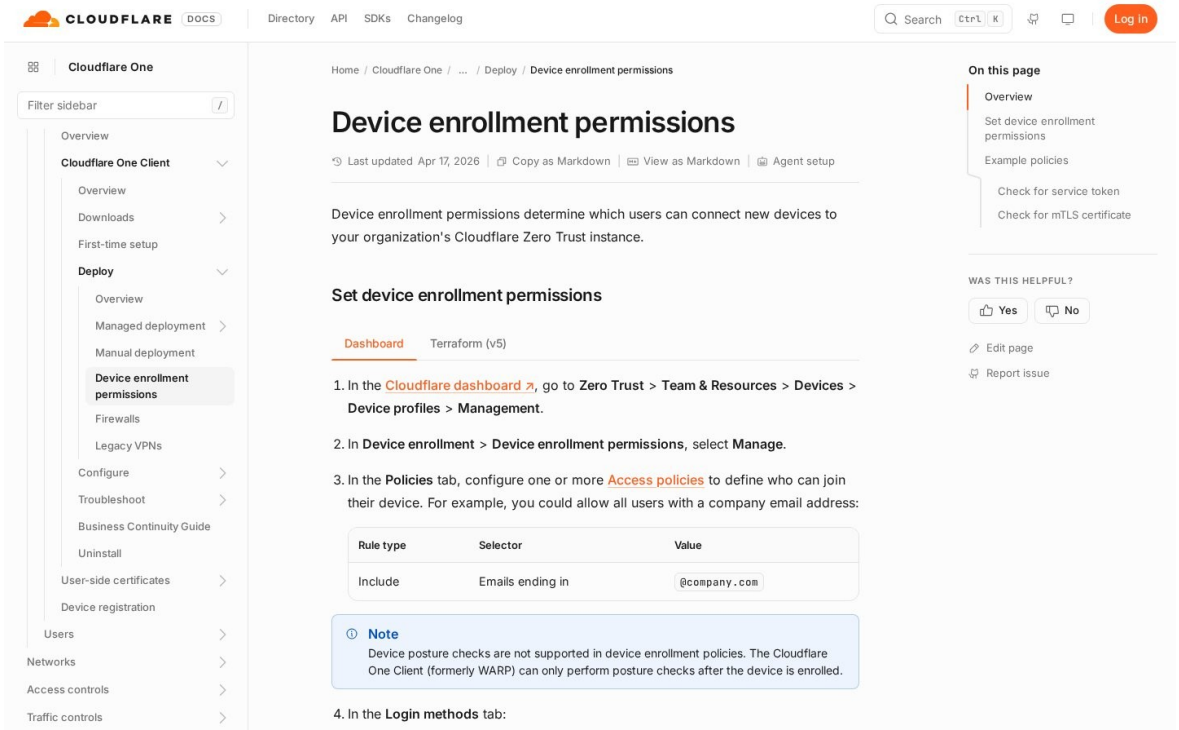
Stage	Doc path	Required steps	Optional
1 Team setup	Get started (account, organization, plan)	4	–
2 Sign-in method	One-time PIN	3	–
	Okta, App Catalog	9	–
	Okta, custom app	14	+3
	Entra ID (18 of the 24 steps are in the Entra admin center)	24	+1
3 Device enrollment	Enrollment permissions	5	–
	Desktop client (GUI)	6	–
	CLI	6	+3
	Mobile	8	+1
4 First policy	DNS filtering (verify setup 5 + create policy 6)	11	–
	Access policy for a private web app	19	+4

Shortest path: 4 + 3 + 5 + 6 + 11 = 29 steps across 5 doc pages (PIN, desktop client, DNS). The Okta catalog path is 35. The Entra path is 50.

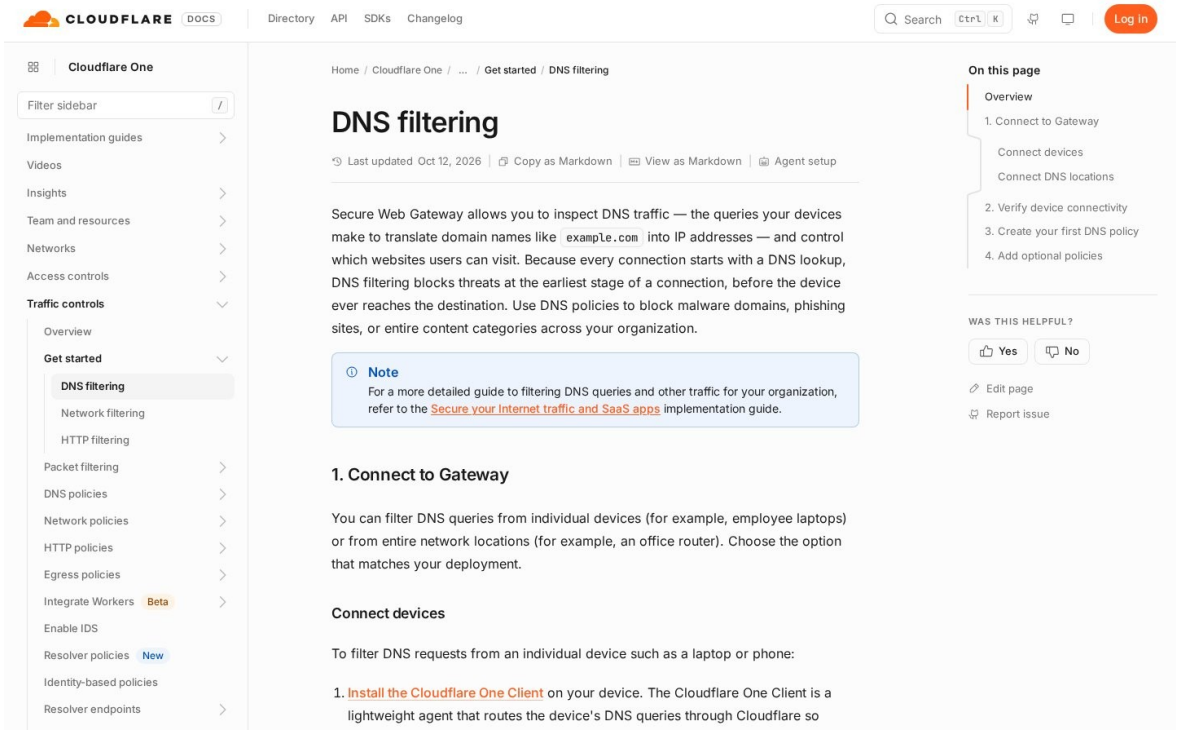
The gap that matters: device enrollment permissions are a separate 5-step page. The Get started page and the DNS filtering guide never mention them. They appear as a prerequisite on the manual deployment page and as step 3 of first-time client setup. An admin who follows the quick start in order can reach the client with no enrollment rule, which matches the most common error in the signals.



Get started page. developers.cloudflare.com/cloudflare-one/setup, accessed 11 Nov 2026



Device enrollment permissions, the page the quick start skips. accessed 11 Nov 2026



DNS filtering quick start: 11 steps to a first policy. accessed 11 Nov 2026

4. Where admins get stuck

56 of the 60 signals describe friction. Eight clusters; the top five cover 50.

Cluster	Signals	Stage	Mostly from
Lost in the console or docs	17	All	G2 8, Reddit 4, X 2, Gartner 2, Community 1
Device refused at enrollment (missing rule or wrong team name)	13	3 (12), 2 (1)	Community 11, Reddit 2
First policy “isn’t working”	8	4	Community 8
Free-plan checkout and team creation	7	1	Community 6, X 1
Sign-in method errors (IdP)	5	2	Community 3, Reddit 2
Policy building, roaming, MDM deployment	2 each	3–4	Mixed

Enrollment refused (13)

The clearest pattern. 11 Community threads from 2022 to Sep 2026 describe the same error, several on brand-new organizations. Replies usually point to a missing enrollment rule or login method, or to typing the full domain instead of the team name.

> “Enrolling any device fails immediately with “Enrollment request is invalid” - this happens before any login/authentication prompt appears”
>
> Cloudflare Community, 8 Sep 2026 (signal 24)

> “What you ought to input is tesla only and not Tesla.cloudflareaccess.com”
>
> Reddit r/CloudFlare comment, 10 Jun 2022 (signal 13)

First policy “isn’t working” (8)

The admin writes a block policy, tests a site, and it loads. Some see the block in the logs while the device still resolves the real address. The docs ask the admin to verify setup first, but there is no single “prove it on this device” check.

> “Gateway DNS block policy shows blocks in the logs, but the macOS Cloudflare One Client still returns the real IP, so blocked test sites load.”
>
> Cloudflare Community, 9 Nov 2026 (signal 27)

Lost in the console (17)

The broadest theme and the least specific. Mostly reviews from people at companies: the product is powerful, but the first weeks are confusing.

> “Followed the Cloudflare “wizard” config/setup experience... Started getting slightly lost amongst various IDP, Tunnel, User, Device, Policy, etc options”
>
> Reddit r/CloudFlare, Sep 2026 (signal 6)

> “the dashboard can be confusing when you’re first learning it. Policy setup sometimes takes more steps than expected”
>
> G2 review, 24 Nov 2025 (signal 51)

Checkout and team creation (7)

The Free plan still asks for payment details (the Get started page says so). Posts describe a disabled button, a checkout that fails, a welcome screen that never clears, and team-name collisions with no clear message.

> “all attempts to enable zero trust have failed at the payment screen after selecting the free account.”

Cloudflare Community reply, 6 Jul 2026 (signal 38)

Sign-in method errors (5)

> “Sign in with AzureAD > “That account does not have access.””
>
> Cloudflare Community, 16 Jan 2025 (signal 48)

Full list with URLs: data/signals.csv. Excluded rows and the reason for each: data/excluded.csv.

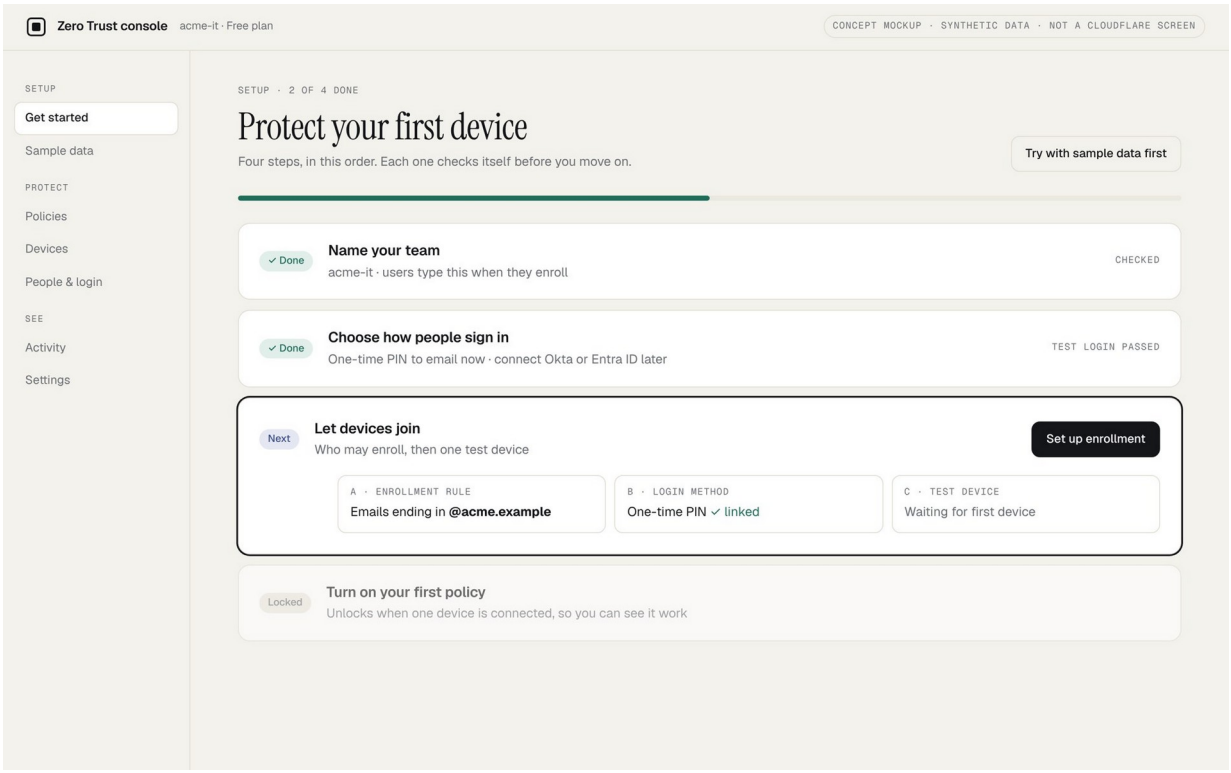
5. The redesign

Four ideas, each tied to a cluster. None of them adds product scope; they change the order and the checks.

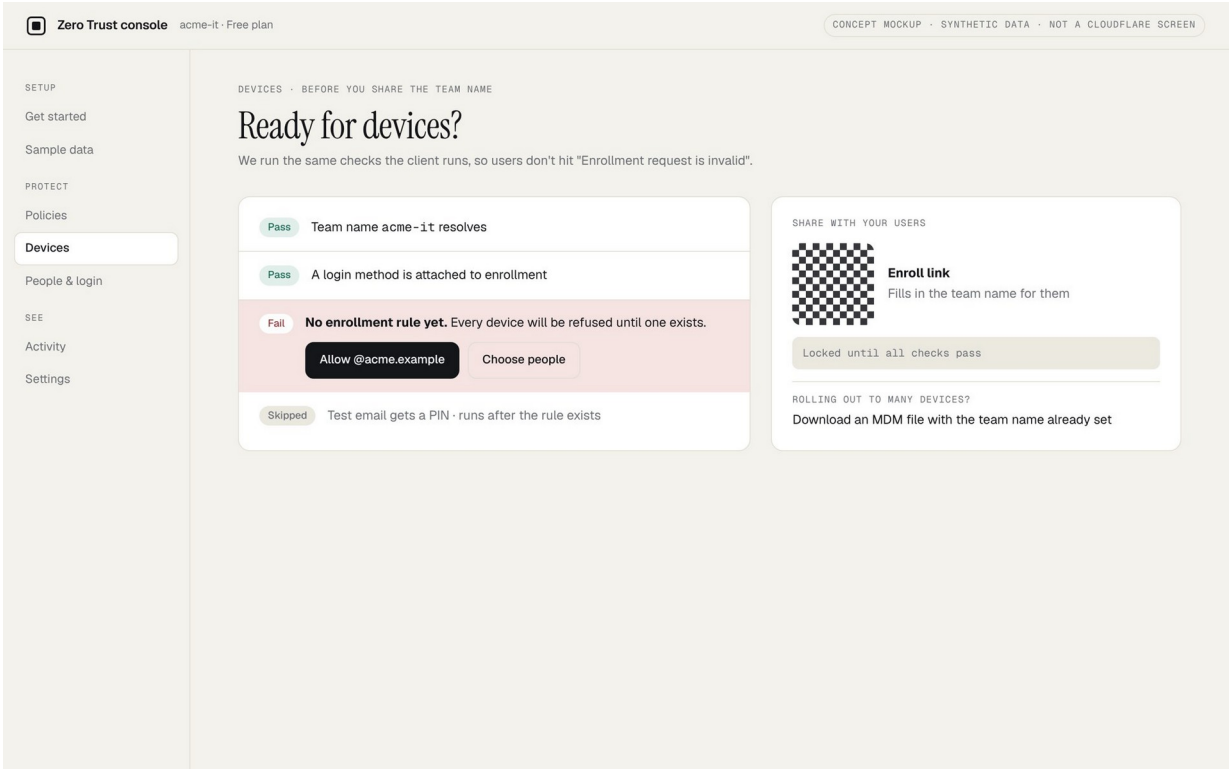
Idea	Fixes	How
Self-checking setup checklist	Lost in console; checkout	One list from signup to first policy. Each item checks the real config and unlocks the next.
Enrollment check	Enrollment refused	Before the first install, confirm a rule and a login method exist; the install link pre-fills the team name.
Guided first policy	Policy “isn’t working”	Start from a template, dry-run it, then prove it on the enrolled test device with a live result.
Sample-data mode	Blank slate; lost in console	A read-only demo org with sample devices, logs and policies, so the console makes sense before real setup.
Setup helper (AI)	Lost in console; sign-in errors	Answers “why is this failing?” from the org’s own config and the docs. Suggests; never changes anything on its own.



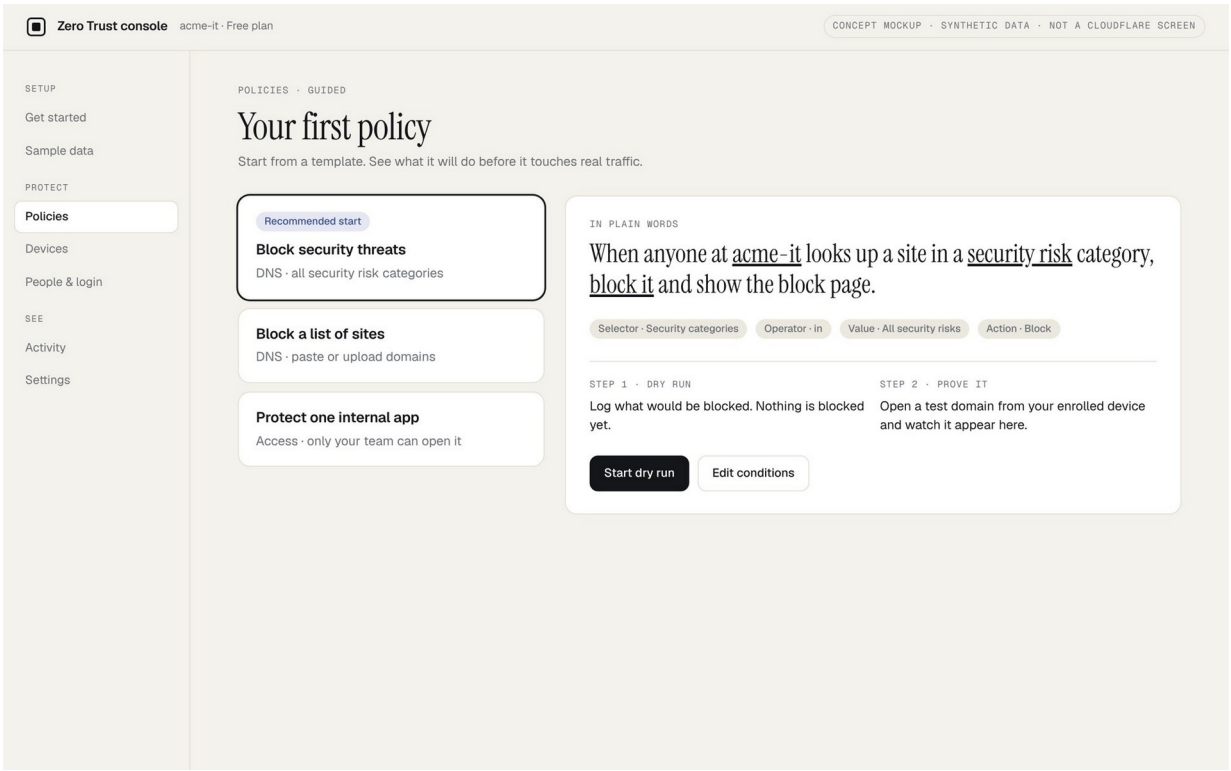
Current vs proposed journey. Counts from data/documented_steps.csv and data/signals.csv.



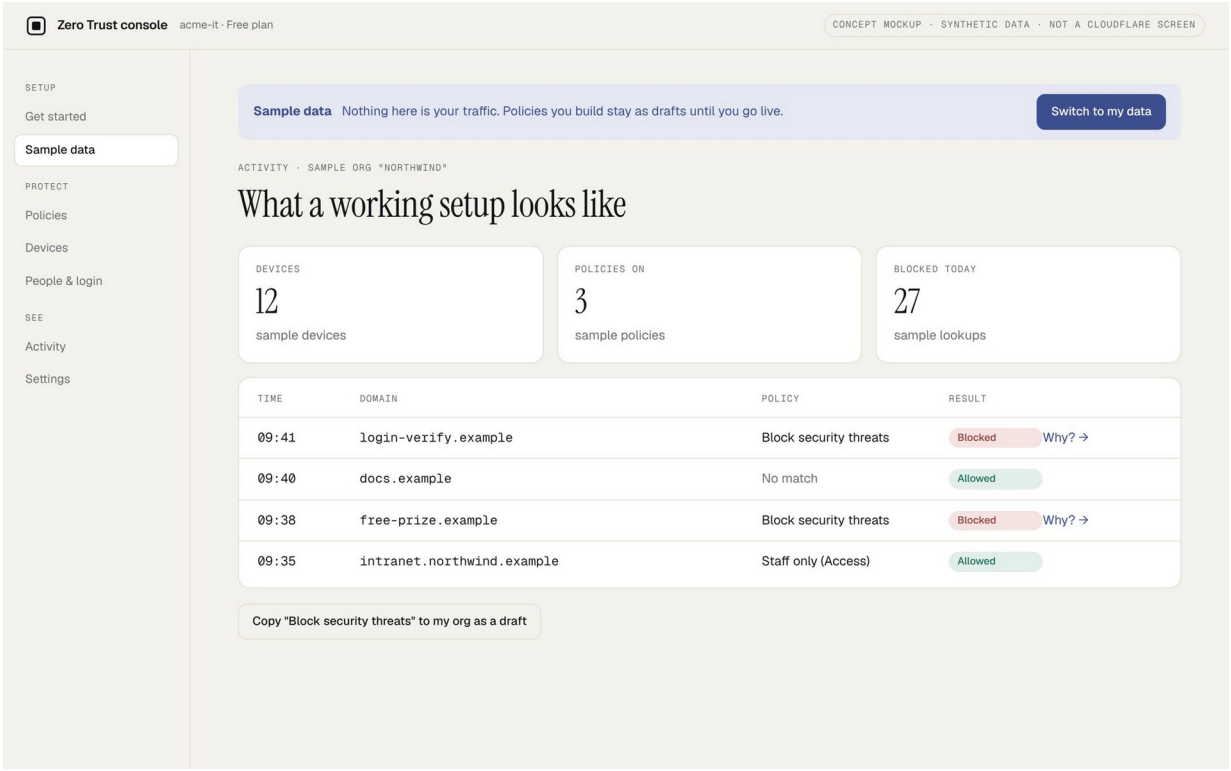
1 · Setup checklist. Checks itself; the next step unlocks when the last one is verified. Concept mockup, synthetic data.



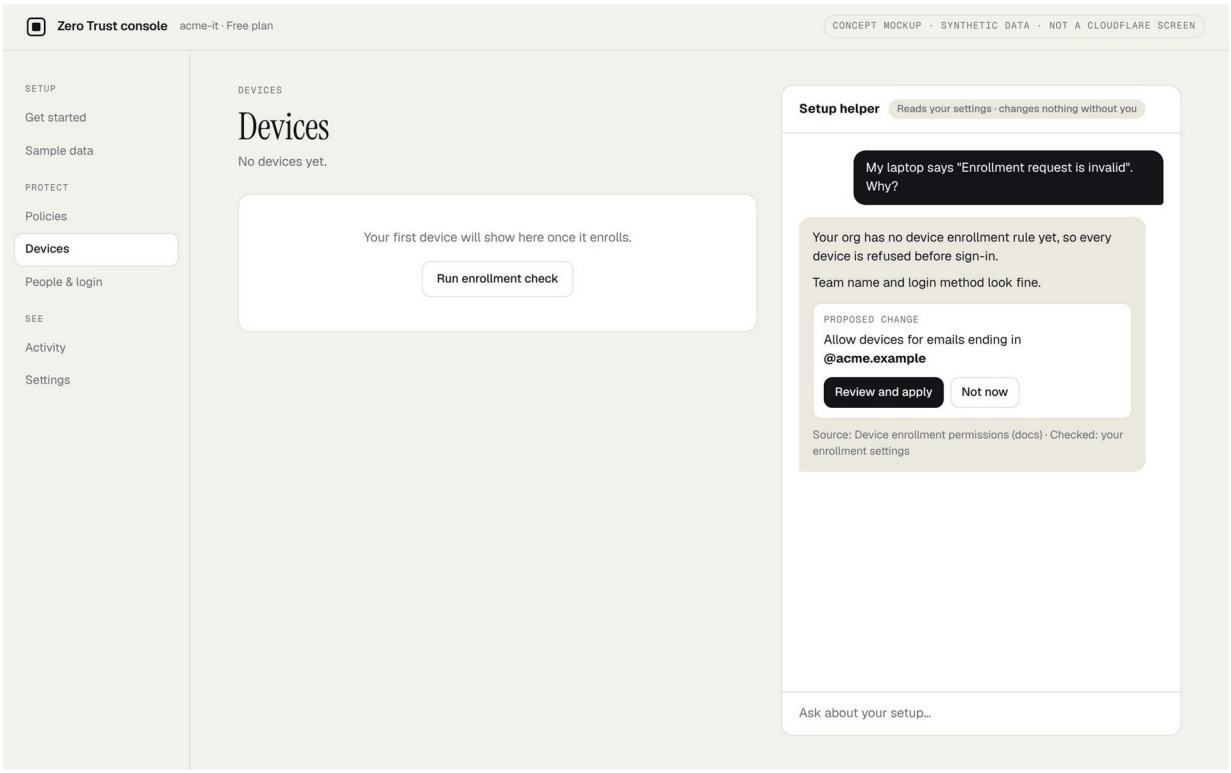
2 · Enrollment check. Catches the missing rule before the first install. Concept mockup, synthetic data.



3 · Guided first policy. Template, dry run, then proof on the test device. Concept mockup, synthetic data.



4 · Sample-data mode. Explore a populated org before touching the real one. Concept mockup, synthetic data.



5 · Setup helper. Reads config, cites docs, proposes changes the admin confirms. Concept mockup, synthetic data.

6. PRD: Guided onboarding to first policy

Problem

New admins on the self-serve path must finish four dependent stages before anything is protected. The docs split those stages across pages, and one prerequisite (device enrollment permissions) is missing from the quick start. Public posts show admins failing at enrollment, doubting their first policy, and getting lost in the console.

Goals

- More new organizations reach activation (one enrolled device with one enforced policy) within [N] days of signup.
- Shorter time from signup to first enforced policy.
- Fewer setup-related support tickets and forum posts per new organization.

Non-goals

- Changing pricing, plans or the checkout itself (checkout bugs go to the billing team as a separate fix).
- Fleet-wide rollout via MDM. This covers the first device, not the hundredth.
- New security features or policy types.
- Letting the AI helper change configuration without the admin confirming.

User stories

1 · Checklist

As a new admin, I want one ordered list of what to do next, so I don't have to stitch together five doc pages.

- Given a new organization, when the admin opens the console, then the checklist shows the four stages in order with the first one open.
- Each item is marked done only when the console detects the real config (not when the admin clicks "done").
- The admin can skip an item; skipped items stay visible and are never marked done.
- Every item links to the matching doc section.

2 · Enrollment check

As a new admin, I want to know my device will be allowed in before I install anything.

- Given no device enrollment rule exists, when the admin opens the install step, then the console blocks it, explains why in one line, and offers to create a rule scoped to the admin's email.
- Given no login method is enabled, the same check offers one-time PIN as the default.
- The install link and instructions show the exact team name to type, with a copy button.
- If enrollment still fails, the console shows the reason from the server side, not only the client message.

3 · Guided first policy

As a new admin, I want to prove my first policy works on my test device.

- The admin can start from a template (for example, block a security category) or from blank.
- A dry run shows what the policy would have matched in recent traffic, or says there is no traffic yet.
- A "test on my device" step checks that the enrolled device is sending DNS through the service and shows the live result for a test domain.
- If the device is not sending traffic, the step names the likely cause and links the fix.

4 · Sample-data mode

As an admin evaluating the product, I want to see a populated org before I set up mine.

- A toggle opens a read-only sample org with synthetic devices, logs and policies, clearly labelled as sample data.
- Nothing in sample mode touches the real organization; copying a sample policy into the real org requires review and confirm.
- Leaving sample mode returns the admin to the same checklist step.

5 · Setup helper

As a stuck admin, I want to ask why something is failing and get an answer about my org.

- Answers cite the doc page they came from.
- The helper can read config and recent setup events; it cannot write. Suggested changes open the normal edit screen for the admin to confirm.
- It never shows secrets, tokens or other users' personal data.
- Each answer has a "this didn't help" control that routes to support with the conversation attached.

Requirements

#	Requirement	Priority
R1	Checklist with state detected from real config, per organization	P0
R2	Enrollment check: rule and login method present before install step	P0
R3	Team name shown and copyable wherever the client asks for it	P0
R4	"Test on my device" check for the first DNS policy	P0
R5	Instrumentation for every checklist step and the activation event	P0
R6	Policy templates with dry run	P1
R7	Read-only sample-data org	P1
R8	AI setup helper, read-only, with citations	P2
R9	Feature flags per organization for every item above, with a kill switch	P0
R10	All new copy and controls meet the console's accessibility standard	P0

Risks

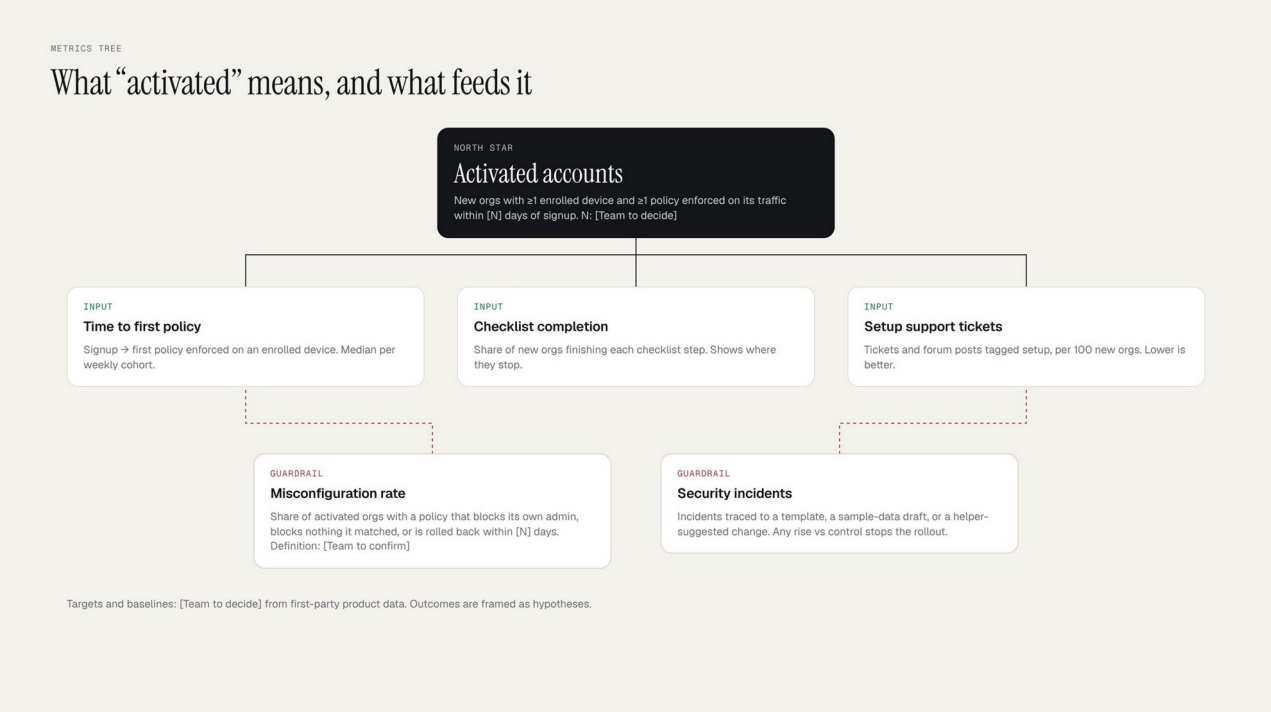
Risk	Mitigation
A template blocks something the company needs	Templates start in log-only mode; the dry run comes first; the guardrail tracks admin lock-outs and rollbacks.
Auto-created enrollment rule is too broad	Default scope is the admin's own email; widening it is an explicit step.
Sample mode delays real setup	Measure time to real activation for sample-mode users; keep the checklist visible in sample mode.
AI helper gives a wrong or unsafe answer	Read-only, cites sources, no secrets; human review of a sample of answers; easy route to support.
Checklist adds noise for experienced admins	Dismissible; hidden once activation is reached.

Rollout

- **Phase 0.** Instrument the current flow (R5) and read the baseline. No user-facing change.
- **Phase 1.** Ship R2 and R3 to everyone. They fix a documented gap and a known error, so they do not need an A/B test; watch the enrollment error rate.
- **Phase 2.** A/B test 1 (checklist) on new organizations.
- **Phase 3.** A/B test 2 (sample data) after test 1 is read, or as a separate randomized arm. [Team to decide]

- **Phase 4.** AI helper as an opt-in beta, behind a flag, with answer review.
- **Exit criteria per phase:** primary metric and guardrails as in section 8. Any guardrail breach stops the rollout.

7. Metrics



North Star, inputs and guardrails.

Metric	Definition	Type
Activated accounts	New orgs with ≥1 enrolled device and ≥1 policy enforced on its traffic within [N] days of signup	North Star
Time to first policy	Signup to first policy enforced on an enrolled device; median per weekly signup cohort	Input
Checklist completion	Share of new orgs finishing each checklist step	Input
Setup tickets	Tickets and forum posts tagged setup, per 100 new orgs	Input
Misconfiguration rate	Share of activated orgs with a policy that blocks its own admin, blocks nothing it matched, or is rolled back within [N] days. Definition: [Team to confirm]	Guardrail
Security incidents	Incidents traced to a template, a sample-data copy or a helper-suggested change	Guardrail

Baselines and targets come from first-party data the team has and I don't: [Team to decide].

8. Experiments

Both tests randomize at the organization level, since admins in one org share setup. Eligible: organizations created after the test starts, on the self-serve path.

Test 1 · Guided checklist vs current console

Hypothesis	If new admins get a checklist that verifies each stage and catches the missing enrollment

	rule, more organizations will reach activation within [N] days, because the most specific public failure is a skipped prerequisite.
Arms	Control: current Get started experience. Treatment: checklist (R1) on top of the same console.
Primary metric	Activation rate within [N] days of signup.
Secondary	Time to first policy; step-by-step checklist drop-off; setup tickets per 100 orgs.
Guardrails	Misconfiguration rate; security incidents; checklist dismiss rate.
Sample size	Per arm: $n = (z_{1-\alpha/2} + z_{1-\beta})^2 \cdot [p_1(1-p_1) + p_2(1-p_2)] / (p_2 - p_1)^2$. p_1 = baseline activation [Team to set], $p_2 - p_1$ = smallest lift worth shipping [Team to set], α [Team to set], power [Team to set]. scripts/sample_size.py runs this with the team's inputs.
Duration	Weeks to enroll = 2n ÷ eligible new orgs per week, rounded up to whole weeks so weekday mix is even. Read the result only after the last cohort has had its full [N]-day window.
Decision rule	Ship if activation is higher with the confidence interval above zero and no guardrail is worse than control. Iterate if the effect is positive but not significant. Stop if any guardrail is worse.

Test 2 · Sample-data mode vs empty state

Hypothesis	If new admins can explore a populated sample org before setup, more of them will create a first policy, because the console starts as a blank slate and the largest theme is getting lost in it.
Arms	Control: empty console with the checklist (or current console if test 1 has not shipped). Treatment: same, plus a sample-data toggle shown on first visit.
Primary metric	Activation rate within [N] days of signup.
Secondary	Time to first policy; share of orgs that open sample mode; policies copied from sample to real org.
Guardrails	Misconfiguration rate (copied sample policies could be wrong for the org); security incidents; time to activation among sample-mode users, so exploring doesn't replace doing.
Sample size	Same formula as test 1. Baseline is the control arm's activation rate after test 1 [Team to set]; MDE, α and power [Team to set].
Duration	Same logic as test 1. If run alongside test 1, use a 2×2 design and size for the smaller of the two effects. [Team to decide]
Decision rule	Ship if activation rises and time to activation for sample-mode users is not worse than control. If more admins open the console but activation is flat, keep sample mode as a demo only.

9. Sources

All accessed 11 Nov 2026. Signal-level URLs are in data/signals.csv; step counts in data/documented_steps.csv.

Get started https://developers.cloudflare.com/cloudflare-one/setup/
First-time client setup https://developers.cloudflare.com/cloudflare-one/team-and-resources/devices/cloudflare-one-client/set-up/
Identity providers https://developers.cloudflare.com/cloudflare-one/integrations/identity-providers/
One-time PIN https://developers.cloudflare.com/cloudflare-one/integrations/identity-providers/one-time-pin/
Entra ID https://developers.cloudflare.com/cloudflare-one/integrations/identity-providers/entra-id/
Okta https://developers.cloudflare.com/cloudflare-one/integrations/identity-providers/okta/
Device enrollment permissions https://developers.cloudflare.com/cloudflare-one/team-and-resources/devices/cloudflare-one-client/deployment/device-enrollment/
Manual deployment https://developers.cloudflare.com/cloudflare-one/team-and-resources/devices/cloudflare-one-client/deployment/manual-deployment/
DNS filtering https://developers.cloudflare.com/cloudflare-one/traffic-controls/get-started/dns/
Private web app https://developers.cloudflare.com/cloudflare-one/setup/secure-private-apps/private-web-app/
Zero Trust plans https://www.cloudflare.com/plans/zero-trust-services/
“Beyond the blank slate” (2 Mar 2026) https://blog.cloudflare.com/cloudflare-one-onboarding-project-helix/
G2 reviews https://www.g2.com/products/cloudflare-one-sase/reviews
Gartner Peer Insights https://www.gartner.com/reviews/product/cloudflare-one?marketSeoName=security-service-edge
Cloudflare Community https://community.cloudflare.com/
Reddit r/CloudFlare, r/sysadmin, r/cybersecurity (thread URLs in signals.csv)
X public posts via search (post URLs in signals.csv)

In short

- Shortest documented path to one protected device: 29 steps, 5 pages. Entra ID makes it 50.
- The quick start skips device enrollment permissions; “enrollment refused” is the most specific public complaint (13 of 56).
- After the first policy, admins can’t easily prove it works (8).
- Fix the order and add checks: checklist, enrollment check, guided first policy, sample data.
- Measure activated accounts; guard against misconfiguration. Two A/B tests, sized by formula once the team sets the inputs.